

TUGAS STUDI KASUS MANAJEMEN RISIKO KEAMANAN INFORMASI

APLIKASI E-COMMERCE SHOPEE

[Fadhli Sanaswan Simangunsong] | [238160056]

1. Aplikasi E-Commerce Shopee

Studi kasus ini mengangkat Shopee, platform e-commerce marketplace yang mempertemukan penjual dan pembeli. Fitur utamanya mencakup pencarian dan pembelian produk lewat aplikasi atau website, pengelolaan toko dan stok oleh penjual (Seller Centre), pembayaran (ShopeePay, transfer virtual account, COD, paylater), pengiriman lewat mitra logistik, promo, voucher, dan flash sale, chat antara pembeli dan penjual, serta layanan pengembalian barang dan pengembalian dana.

Sistem seperti ini menarik dianalisis dari sisi keamanan karena mengelola data pribadi dan data transaksi pembayaran dalam jumlah sangat besar, melayani jutaan pengguna secara bersamaan, dan melibatkan banyak pihak (pembeli, penjual, kurir, mitra pembayaran) dengan beragam perangkat. Lonjakan trafik pada kampanye besar seperti 9.9, 11.11, dan 12.12 memperbesar tekanan pada sistem, sementara popularitas Shopee membuatnya menjadi target penipuan dan serangan siber.

Sesuai ketentuan tugas, analisis ini tidak melakukan penetration testing terhadap sistem milik pihak lain. Temuan disusun dari observasi pasif di sisi pengguna (alur pembelian, tampilan aplikasi, label resi, pesan penipuan yang beredar, dan perilaku aplikasi saat trafik tinggi) ditambah pemahaman umum arsitektur platform e-commerce, sehingga sifatnya indikatif dan bukan hasil pengujian teknis terhadap sistem Shopee. Kontrol existing yang dicantumkan adalah kontrol yang tampak bagi pengguna atau umum dimiliki platform sejenis.

2. Matriks Penilaian Risiko

Penilaian risiko menggunakan skala 1-5 untuk kemungkinan (likelihood) dan dampak (impact), dikalikan untuk mendapatkan skor prioritas risiko. Berikut matriks yang digunakan sebagai acuan:

Kemungkinan \ Dampak	1	2	3	4	5
5 (hampir pasti)	5	10	15	20	25
4 (sering)	4	8	12	16	20
3 (mungkin)	3	6	9	12	15
2 (jarang)	2	4	6	8	10
1 (sangat jarang)	1	2	3	4	5

Keterangan: Rendah (1-4) | Sedang (5-9) | Tinggi (10-14) | Kritis (15-25)

3. Identifikasi Aset, Ancaman, Kerentanan, dan Prioritas Risiko

Berdasarkan hasil observasi, berikut sembilan temuan yang mencakup aset-aset utama pada Shopee, meliputi database pengguna dan pesanan, akun, pembayaran, aplikasi dan API, sistem pesanan dan stok, Seller Centre, infrastruktur server, promo dan voucher, hingga perangkat pengguna.

No	Aset	Ancaman	Kerentanan	Dampak	Kontrol Existing	Bukti/Observasi	K	D	Prioritas Risiko
1	Database pelanggan & pesanan	Kebocoran data pribadi pengguna (nama, nomor HP, alamat, riwayat pembelian)	Data pribadi terkumpul dalam jumlah besar, dibagikan ke banyak pihak (penjual, kurir, mitra logistik), dan akses internal berpotensi terlalu luas	Data terungkap, penyalahgunaan untuk penipuan atau spam, kepercayaan pengguna turun, potensi sanksi UU PDP	Kebijakan privasi, penyamaran sebagian data pada aplikasi, login dengan verifikasi OTP	Label resi paket mencantumkan nama, nomor HP, dan alamat penerima sehingga terlihat oleh kurir dan orang lain; paket atau label bekas sering dibuang tanpa dihancurkan.	3	4	12 (tinggi)
2	Akun pembeli, penjual, dan ShopeePay	Pengambilalihan akun (phishing, credential stuffing, pencurian OTP)	Password dipakai ulang di banyak layanan, pengguna mudah tertipu tautan atau pesan palsu, OTP dibagikan ke pihak lain	Saldo ShopeePay dan limit paylater terpakai, pesanan dan data pribadi disalahgunakan	OTP nomor HP, notifikasi login dan transaksi, PIN pembayaran, imbauan waspada penipuan	Pesan SMS atau WhatsApp yang mengatasnamakan Shopee (hadiah, refund, verifikasi akun) beredar luas dan meminta kode OTP atau data login.	4	4	16 (kritis)
3	Sistem pembayaran (ShopeePay, virtual account, COD, paylater)	Penipuan pembayaran dan manipulasi status pembayaran	Pengguna diarahkan membayar di luar platform atau lewat tautan palsu, serta pemeriksaan tujuan pembayaran bergantung pada kewaspadaan pengguna	Uang berpindah ke pihak penipu, pesanan tidak diterima, sengketa dan kerugian finansial	Garansi Shopee (dana ditahan sampai pesanan diterima), penyelenggara pembayaran resmi, PIN atau biometrik	Ada modus penjual yang mengajak transaksi lewat chat atau transfer langsung dengan iming-iming harga lebih murah, dan tautan pembayaran palsu yang menyerupai halaman Shopee.	3	5	15 (kritis)
4	Aplikasi & API pemesanan	Manipulasi harga, jumlah, ongkir, atau voucher pada permintaan checkout (parameter tampering)	Sebagian perhitungan dan validasi berpotensi dilakukan di sisi klien, sehingga bergantung pada kuatnya validasi di server	Pesanan dengan harga tidak sesuai, kerugian pendapatan dan penjual	Validasi di formulir dan aplikasi, autentikasi sesi, pemantauan transaksi	Nilai seperti harga, jumlah, dan kode voucher dikirim sebagai parameter permintaan dari aplikasi sehingga secara arsitektur menjadi titik yang perlu divalidasi ulang di server (indikatif, tidak diuji).	2	5	10 (tinggi)
5	Sistem antrean pesanan & stok (flash sale)	Pesanan ganda, hilang, tertahan, atau stok terjual melebihi persediaan (overselling)	Lonjakan trafik pada kampanye besar, sinkronisasi stok dan pesanan bergantung pada koneksi dan mekanisme retry	Pesanan dibatalkan sepihak, pelanggan dan penjual komplain, reputasi turun	Reservasi stok sementara saat checkout, pembatalan otomatis, layanan pelanggan	Saat flash sale atau tanggal kembar (mis. 11.11), pesanan kadang gagal diproses, stok berubah saat checkout, atau muncul status pembayaran yang tertunda.	4	3	12 (tinggi)

No	Aset	Ancaman	Kerentanan	Dampak	Kontrol Existing	Bukti/Observasi	K	D	Prioritas Risiko
6	Seller Centre (toko, produk, harga)	Perubahan harga atau listing tanpa otorisasi oleh akun toko yang diambil alih atau orang dalam; listing palsu	Akun toko dapat dikelola beberapa orang, tanpa persetujuan berlapis dan audit log yang terlihat bagi penjual	Harga tidak konsisten, produk fiktif atau palsu, laporan penjualan tidak akurat	Login penjual, verifikasi toko, moderasi listing, laporan produk	Terlihat produk dengan harga tidak wajar atau listing berulang dari toko baru, dan tidak tampak mekanisme persetujuan tambahan untuk perubahan harga besar.	3	3	9 (sedang)
7	Server & jaringan platform	Downtime atau serangan DDoS saat trafik puncak	Ketergantungan pada satu titik layanan tertentu dan lonjakan trafik ekstrem pada kampanye besar	Pesanan tidak bisa masuk, pendapatan penjual dan platform hilang, pengguna beralih ke pesaing	Infrastruktur cloud, CDN, pemantauan dan tim operasi 24 jam (umumnya diasumsikan)	Pada jam ramai dan kampanye besar aplikasi kadang lambat, gagal memuat halaman, atau muncul pesan kesalahan sementara.	3	4	12 (tinggi)
8	Promo, voucher, koin, dan gratis ongkir	Penyalahgunaan voucher lewat akun ganda, bot, atau otomatisasi	Kode promo dapat dibagikan luas dan sulit dibatasi per orang atau perangkat, ada insentif ekonomi untuk akun palsu	Anggaran promo terkuras, margin turun, pengguna sah kehabisan voucher	Batas masa berlaku, kuota, syarat pemakaian per akun	Kode voucher beredar di media sosial dan grup, cepat habis dalam hitungan detik, dan sebagian orang tampak memakai banyak akun.	4	2	8 (sedang)
9	Perangkat & aplikasi pengguna	Pemakaian aplikasi tidak resmi (APK modifikasi), perangkat hilang atau tetap login, Wi-Fi publik tidak aman	Pengguna memasang aplikasi dari sumber tidak resmi, tidak memakai kunci layar, dan sering login di jaringan terbuka	Akun dan data di perangkat diakses pihak tidak berwenang	Sesi login terbatas waktu, verifikasi untuk perangkat baru	Tautan unduhan aplikasi Shopee tidak resmi beredar di internet, dan banyak pengguna tetap login di perangkat bersama atau jaringan publik.	3	2	6 (sedang)

Keterangan: K = Kemungkinan, D = Dampak (skala 1-5).

4. Rekomendasi Perbaikan

Dari sembilan temuan di atas, disusun tujuh rekomendasi kontrol (melebihi syarat minimal lima) yang masing-masing mengacu pada risiko yang paling relevan.

No	Risiko Terkait	Rekomendasi Kontrol
1	Kebocoran data pelanggan (#1)	Mengenkripsi data pribadi saat disimpan dan dikirim, membatasi akses internal dengan RBAC, menyamarkan nama, nomor HP, dan alamat pada label resi, menetapkan kebijakan retensi data, serta menyesuaikan pengelolaan data dengan UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi.
2	Pengambilalihan akun & perangkat (#2, #9)	Mewajibkan MFA untuk transaksi sensitif, mendeteksi login dari perangkat atau lokasi tidak biasa, menerapkan rate limiting dan deteksi bot terhadap credential stuffing, mengedukasi pengguna soal phishing dan larangan membagikan OTP, serta hanya memakai aplikasi resmi.
3	Penipuan pembayaran (#3)	Mendorong seluruh pembayaran tetap di dalam platform, memberi peringatan otomatis pada chat yang mengajak transaksi di luar Shopee, memverifikasi tautan dan domain resmi, menerapkan PIN atau biometrik, serta melakukan rekonsiliasi transaksi dan deteksi fraud secara berkala.
4	Manipulasi parameter checkout (#4)	Menghitung harga, ongkir, dan voucher sepenuhnya di sisi server, memakai permintaan bertanda tangan (signed request) dengan perlindungan replay, membatasi jumlah dan nilai pesanan yang wajar, serta memasang WAF dan pemantauan anomali API.
5	Flash sale & downtime (#5, #7)	Memakai antrean pesan dengan retry dan idempotency, reservasi stok atomik saat checkout, auto-scaling, CDN, dan proteksi anti-DDoS, load testing sebelum kampanye besar, serta rencana pemulihan bencana (DRP) dan mode degradasi yang aman.
6	Perubahan harga & listing toko (#6)	Menerapkan MFA untuk akun penjual, persetujuan tambahan untuk perubahan harga yang ekstrem, audit log yang tidak bisa diubah, serta deteksi otomatis listing mencurigakan.
7	Penyalahgunaan voucher (#8)	Membatasi voucher per akun, nomor HP, dan perangkat, memakai kode sekali pakai untuk promo bernilai besar, memasang deteksi bot saat checkout, dan memantau pola pemakaian yang tidak wajar.

5. Kesimpulan

Dari sembilan temuan yang diperoleh, ada dua risiko yang masuk kategori kritis, yaitu pengambilalihan akun lewat phishing atau pencurian OTP (skor 16) dan penipuan pembayaran yang mengalihkan transaksi ke luar platform (skor 15). Keduanya sebaiknya jadi prioritas utama karena langsung berkaitan dengan uang dan data pribadi pengguna. Empat risiko lain berada di kategori tinggi (kebocoran data pelanggan, manipulasi parameter checkout, gangguan pesanan saat flash sale, dan downtime saat trafik puncak), sedangkan tiga sisanya berkategori sedang. Rekomendasi kontrol yang diberikan diharapkan menjadi langkah awal untuk menurunkan tingkat risiko tersebut ke level yang lebih dapat diterima.